Zinvest AI Accountant: Security Self-Assessment

How permissions are tiered and enforced, which controls protect the system, and the risks we know about.

System: Zinvest AI Accountant (https://zinvest-kappa.vercel.app) **Assessment date:** 18–20 October 2026

Method: code review, automated tests, black-box checks of production

1. Scope and method

- **Code review** of the whole backend and frontend, focused on authentication, authorisation, the AI flow, uploads, rate limits and secrets. Findings were fixed and re-tested before this document was written (Section 5).
- **Black-box checks of production**, read-only: about 60 requests. They checked for exposed files (`.env`, `.git`, sources, source maps), anonymous access to every API area (27 endpoints, all answer 401), CORS, security headers, error verbosity, forged tokens and old deployments (protected by Vercel authentication).
- **Automated tests:** 276 backend tests, among them tests for rate limits, automatic bans, admin permissions, session theft detection, email-change confirmation, the upload sandbox and validation of the AI's answers.

2. Permission tiers

2.1 What the AI may do

Tier	Actions	Who decides	How it is enforced
0. Read and compute	Read the signed-in owner's own records and business profile; compute averages, cash runway, loan payments and the forecast (in code).	Automatic	Every query is filtered by the signed-in user. No access to other people's data, account details or credentials.
1. Propose	Read the owner's text into records, analyse, warn about cash, compare loans, draft a business plan.	Automatic, but only as a *pending proposal*	The answer is stored as `CopilotAction` with status *pending* and the list of effects approval would have. Nothing in the books changes.
2. Change business data	Add the records to the books, save the analysis, forecast, loan choice or plan, add tasks to the to-do list.	**The owner, per proposal** ("Yes, approve" / "No")	Only `POST /api/copilot/actions/<id>/decide` applies effects. It runs in one transaction with a row lock, checks the proposal belongs to the caller and is still pending (a second decision gets 409), and stores what was changed. "No" changes nothing.
3. Never	Move or pay money, apply for a loan, contact a bank or any third party, delete data, change account or security settings, act on another account.	Not possible	The model has **no tools** and no credentials. It only returns JSON text, which the server validates; there is no code path from a model answer to these actions.

2.2 People and staff roles

Role	Access

Owner / learner	Their own data only. AI Accountant proposals and decisions; history export as CSV / PDF; personal data export and account deletion.
Staff: owner, admin, support, content, analyst	A permission matrix: for example only *owner* manages the team and deletes accounts, *support* can switch accounts off and sign people out but cannot see security logs, *content* edits lessons only, *analyst* is read-only.
Admin panel step-up	Every staff session must confirm "it's me" (password and, where enabled, a TOTP code) before the panel opens; that confirmation is tied to the device's session. Any change additionally needs a step-up no older than 30 minutes. Every staff change goes to an audit log nobody can edit.

3. Security controls

Identity and sessions

- Access tokens: JWT, HS256 with the algorithm pinned, a dedicated signing key, 15-minute life, kept only in memory in the browser.
- Refresh tokens: opaque, 512-bit, stored only as SHA-256 hashes, rotated on every use. Re-use of an old token revokes the whole session family (theft detection). Sent only in an HttpOnly, Secure, SameSite=Strict cookie limited to the refresh path.
- Sign-in with Google: OAuth 2.0 with PKCE, a signed state cookie, checks of issuer, audience and verified email; only the production site is an allowed return address.
- Password sign-in is throttled per account, per address and per email, with atomic counters. Every request re-checks that the account is active and its tokens have not been revoked.
- Changing the sign-in email takes effect only after the new address opens a confirmation link. The old address is told, and every session is ended.
- "Sign out everywhere", a password change or reset, and an account being switched off or banned end every session, including a linked Telegram chat.

Abuse and cost protection

- **Three layers of rate limits:** a Vercel firewall rule per IP on `/api`; per-user (or per-IP for guests) limits for reads, writes, uploads and AI calls, counted in an atomic database counter shared by all server instances; strict limits inside sign-up, sign-in, codes and password reset.
- **Automatic bans:** a client that keeps sending requests after being told to slow down (twice a limit in one window) is banned at once. A signed-in account is banned permanently and signed out everywhere. A network address is blocked for 1 hour, then 24 hours, then 30 days. Only the sender is banned, never the account under attack. Staff accounts and the server itself are never banned automatically. Staff can see bans and live counters and lift a ban.
- **AI cost:** a monthly token allowance per person, a size limit on every question, a global "AI off" switch for staff, and the same limits applied to the Telegram bot.

AI-specific risks

- **Hallucinated numbers:** all figures are computed in code; the model explains them. Amounts read from text must be real positive numbers; a loan must be a product from the catalogue; anything unreadable is shown to the owner as "unclear".
- **Prompt injection:** the owner's text is marked as untrusted data in the prompt. Even if the model followed it, the model has no tools, its output is validated and can only become a pending proposal for that same owner.
- **Unrealistic advice:** the prompt forbids extreme moves (cutting a cost line to zero, firing everyone); the owner reviews every proposal before it changes anything.

Data protection

- Uploaded images are checked by their bytes, renamed by the server and served with the server's own content type inside a sandbox (`Content-Security-Policy: sandbox`, `Cross-Origin-Resource-Policy: same-origin`, `nosniff`), so a file cannot run as a web page.
- HTTPS only with HSTS; a strict Content-Security-Policy; `frame-ancestors 'none'`; API answers are `no-store`.
- Secrets (database URL, signing keys, AI and bot keys) exist only in Vercel's encrypted environment variables, never in the repository or the deploy bundle. Debug mode is off unless explicitly turned on locally.
- Retention: expired sessions, one-time codes (after a day), used links (after a week) and the security log (after 180 days) are deleted by a daily job. Email addresses are masked in server logs.

4. Known risks

#	Risk	Level	Status and mitigation
1	The model's advice can be wrong or too generic for a specific business.	Medium	Numbers come from code; every proposal needs approval; realism rules in the prompt. Residual: the quality of the advice text. The owner stays the decision-maker.
2	Bank loan terms change; the catalogue is static (October 2026).	Medium	Shown as indicative with links to the banks' pages; payments use the upper end of the rate range. Plan: refresh the catalogue monthly.
3	The AI allowance is checked before a call, not reserved, so parallel requests can slightly exceed it.	Low	Bounded by 20 AI calls per minute per person and automatic bans. Plan: reserve tokens atomically before each call.
4	Email delivery is not live yet, so sign-up and sign-in confirmation codes are switched off in production.	Medium	Accounts work; email ownership is confirmed by link when mail is available. Plan: send through a transactional provider on the zinvest.uz domain, then turn codes on.
5	Automatic address bans can hit innocent people sharing one IP (a school, a mobile carrier).	Low	Address bans only stop guests, are temporary and escalate slowly; signed-in people on the same network are not affected; staff can lift a ban in one click.
6	Business figures are sent to Google's Gemini API (processing outside Uzbekistan).	Low	Only the business profile (no people's names: team members appear by job title) and its figures are sent, never passwords, tokens or other accounts' data. Disclosed in the privacy policy; a self-hosted model is possible later.
7	Staff can create a one-time password link for a user and see it (to help people without access to their email).	Low	Owner/admin/support only, 1-hour single-use link, audited with the staff member's name. Option: send it only to the user's email.
8	The Content-Security-Policy allows images from any HTTPS host.	Low	Needed for lesson images; only matters after an XSS, of which none is known. Plan: limit to known hosts.
9	One database region, no tested disaster-recovery drill.	Low	Backup coverage depends on the Supabase plan. Plan: a scheduled export and a restore drill.
10	Dependence on the Gemini API quota and availability.	Low	Automatic fallback to another Gemini model; without AI the app still works and AI steps say so clearly.

5. Found and fixed during this assessment

Level	Finding	Fix

High	An uploaded "image" could be served with a browser-chosen type and run as a page on the main site.	The server chooses the type from the extension it set; uploads are served in a sandbox. Production checked: no such files existed.
High	A linked Telegram chat kept working after a password reset, "sign out everywhere" or a ban.	All of these now unlink Telegram; the bot ignores switched-off accounts and respects the AI switch and allowance.
Medium	The sign-in email changed at once, without proof of the new mailbox.	The change now waits for the new address's confirmation link; the old address is told; the same answer whether or not the address is taken.
Medium	Sign-in lockout counters were not atomic on serverless hosting.	Moved to the atomic database counter.
Medium	No size limit on AI questions; study-plan rebuilds unlimited.	Question and context limits; rebuilds limited and counted as AI calls.
Medium	Uploaded files had no rate limit; debug mode defaulted to on if a setting was missing.	`/media` is rate-limited; debug is off unless explicitly enabled.
Low	Google sign-in accepted localhost as a return address in production; upstream AI errors were shown to users; email addresses appeared in logs.	Production allows only its own address; generic AI errors; emails masked in logs.

Fixes were deployed to production on 18 October 2026 after the database migrations, and verified on the live site (security headers, sandboxed uploads, Google return address, rate-limit counters).